

What **Everyone** Should Know About Open Source Compliance

Open source is now inevitable for companies that want to thrive in a hyper-competitive world. There is currently no place for the old fear, uncertainty and doubt related to using open source software as it's difficult to imagine a modern technology company that doesn't use open source components.

We now have a global consensus in favour of a certain way of making things—by collaborating and sharing—as demonstrated by the success of open source. Even Microsoft, a historical rival of FOSS, has made huge strides in adopting open source under the leadership of its CEO Satya Nadella. In 2018, after acquiring GitHub, Microsoft also joined the Open Invention Network (OIN), the largest patent non-aggression community in history that supports freedom of action in Linux as a key element of open source software. The OIN is funded by Google, IBM, NEC, Philips, Red Hat, Sony, SUSE and Toyota; it has more than 2,650 community members and owns over 1,300 global patents and applications. The OIN patent licence and member cross-licences are available royalty-free to any party that joins the OIN community. In India, the Software Freedom Law Center organised the inaugural event for the OIN, in order to educate Indian companies on the benefits of joining a patent pool as a defence mechanism.

With IBM agreeing to acquire Red Hat for a total value of approximately US\$ 34 billion, the biggest Linux or open source business deal ever, the importance of open source in today's technology environment has been further bolstered.

'Software governance' is the phrase we use to describe the processes by which businesses document and control what software they use, what software they distribute, and the terms they offer on inbound and outbound transactions. Whether the business is selling physical products with software embedded, like phones or software products and services, good software governance is the cost-effective way to prepare to meet compliance obligations. Contemporary products, from cars and home appliances to networking or entertainment devices, may each contain dozens of computers, each one of them, in turn, containing a full stack of embedded software. This is typically a mix of GPL or copyleft licensed software, other open source software, and proprietary programs. Whether yours is a large company with dedicated resources for compliance or a small player, adhering to a few basic principles would help to avoid 90 per cent or more of the compliance issues that arise. Here we examine a few of them.



First, always view your compliance obligations from the viewpoint of the user downstream, who receives your product. It helps to ask yourself if the user received notice of the GPL software intentionally included in your product? Is complete, corresponding source code and applicable installation information easily available to the user, preferably by automated means? If not, do take steps to ensure these issues are always addressed.

Second, if you rely on an upstream provider for your software, always exercise your own right to request complete and corresponding source code for all the copyleft licensed work from all software providers and from makers of components with embedded software, preferably in an automated process directly feeding your overall software governance system. They are under obligation to provide you complete and corresponding source code in just the way that you are obligated to provide it to your customers.

Third, don't blindly invest in scanning tools. They are expensive and almost never catch the problems that have historically resulted in litigation in the open source community. Try building comprehensive compliance teams. Use them, where they are cost-effective, as a supplement to your own governance and verification processes, not as a primary tool of risk management.

Fourth, concentrate on the GPL software you know you are using. Historically, the risk of a copyleft licensed code snippet being dropped in your proprietary product by a programmer, unmindful of the consequences, is rare and fairly easy to resolve.

Fifth, hire professionals to help build internal teams, to teach or train your staff on compliance for the long term, and not rely on outside counsel for a few hours. In-house open source expertise will go a long way in helping you deliver compliant products for many years to come. **END** 🐧

By: Mishi Choudhary

The author is the managing partner of Mishi Choudhary Associates. She is a technology lawyer and an online civil liberties activist. Being a frequent commentator on issues related to technology and policy, she has worked extensively for the rights of Internet users and free software developers in India.